REPLACE AND MODERNIZE LEGACY VPN ARCHITECTURES WITH A CLOUD NATIVE ZSCALER ZERO TRUST SOLUTION TO REDUCE ATTACK SURFACE AND LATERAL MOVEMENT

S.No	Name	College	Email
1	Divyaprabha M	AVP College of Arts and Science	divyaprabhavijaya2005@gmail.com
2	Abinay R	AVP College of Arts and Science	abinayaramasamy2006@gmail.com
3	Kiruthika R	AVP College of Arts and Science	kiruthikakalaivaani2005@gmail.com
4	Pooja sri M	AVP College of Arts and Science	poojasrimurugan299@gmail.com
5	Pradeepa S	AVP College of Arts and Science	pradeepasekar13@gmail.com

PROJECT DETAILS

Title: Replace And Modernize Legacy Vpn Architectures With A Cloud Native Zscaler Zero Trust Solution To Reduce Attack Surface And Lateral Movement

Introduction:

Legacy VPN architectures have been the standard solution for remote access and connecting branch offices to corporate networks. While effective in providing connectivity, traditional VPNs grant broad network access to users, which can increase the risk of security breaches and make lateral movement easier for attackers if a single account or device is compromised.

The growing complexity of enterprise networks, combined with the rise of remote work, has exposed limitations in legacy VPN systems, including scalability challenges, high maintenance costs, and lack of granular access control.

Zscaler's cloud-native Zero Trust solution addresses these challenges by enforcing the principle of "never trust, always verify". Instead of providing access to an entire network, Zscaler Zero Trust only allows users to reach the applications they are explicitly authorized to use.

This approach significantly reduces the attack surface, prevents lateral movement across the network, and ensures sensitive resources remain protected. By leveraging the cloud, organizations no longer need to maintain on-premises VPN concentrators or backhaul traffic through data centers, which improves performance and simplifies IT management.

Furthermore, Zscaler provides continuous monitoring and risk assessment, ensuring that user devices comply with security policies before granting access. This enhances compliance with industry standards and regulatory requirements.

The transition to a cloud-native Zero Trust architecture also supports scalability, enabling secure access for employees, contractors, and third-party vendors, regardless of their location. It allows enterprises to modernize their security posture, improve user experience, and reduce operational complexity.

Abstract:

This project focuses on the strategic migration from a traditional Virtual Private Network (VPN) infrastructure to a cloud-native Zero Trust Network Access (ZTNA) solution offered by Zscaler. The motivation behind this transition arises from the growing limitations of legacy VPN architectures in addressing modern cybersecurity threats. Conventional VPN systems operate on a "connect first, verify later" principle, which grants users extensive access to the internal network. This approach increases the risk of unauthorized access and enables attackers to move laterally across the network if a device or user account is compromised. Additionally, maintaining physical VPN appliances, handling complex configurations, and managing inefficient traffic routing often results in operational challenges and poor user experience, especially for organizations supporting a hybrid workforce.

To address these challenges, the proposed solution utilizes the Zscaler Zero Trust Exchange, a globally distributed cloud platform that transforms traditional network-based access into an identity- and application-centric security model. In this architecture, corporate applications are hidden from the public internet, and secure connections are established directly between authenticated users and the specific applications they are authorized to access. As a result, users gain access only to required applications rather than the entire network, which effectively eliminates the possibility of lateral movement by attackers. Furthermore, traffic is routed directly through Zscaler's cloud edge, improving performance and providing a seamless user experience regardless of the user's location.

The implementation of this modern security architecture is expected to deliver multiple benefits. It will significantly reduce the organization's attack surface while eliminating risks associated with lateral movement. At the same time, security management becomes simpler and more scalable through a centralized cloud-based administration console. This reduces operational complexity, lowers infrastructure costs, and enhances overall efficiency. Ultimately, migrating to a Zero Trust architecture strengthens cybersecurity defenses while supporting a secure, flexible, and high-performance digital work environment. This transformation ensures that the organization's security framework remains resilient and adaptable to evolving threats and future technological demands.

Use Case Scenarios:

Scenario 1: Third-Party Vendor Access to Finance Application

An external auditor requires temporary access to the university's finance application for end-of-year financial reconciliation. Instead of creating a traditional VPN account, access is provided through **Zscaler Private Access (ZPA)** with a time-limited and application-specific policy. The vendor authenticates using the organization's identity provider, and access is strictly limited to the finance application through micro-segmentation, preventing visibility of other internal systems.

Output:

- User identity verified (**External_Auditor_Group**)
- Time-restricted access enforced (**7-day validity**)
- Connection allowed only to the **Finance Application**
- No possibility of lateral movement to other resources

Scenario 2: Research Assistant Access to High-Performance Computing Cluster

A graduate research assistant needs SSH access to an on-premises high-performance computing (HPC) cluster to execute data analysis tasks. With **Zscaler Private Access (ZPA)**, the student connects securely to the cluster without exposing SSH services to the public internet or requiring a full network-level VPN connection.

Output:

- User identity verified (**Research_Assistant_Group**)
- Access limited to the **SSH protocol** only
- Secure micro-tunnel established directly to the **HPC Cluster**
- All other network resources remain inaccessible

Scenario 3: Administrative Staff Access to Internal File Server

An administrative staff member working from a remote campus office needs access to an internal file server containing confidential student records. **Zscaler Private Access (ZPA)** verifies the user's identity and device posture before granting secure access. Traffic is routed only to the required file server while being inspected inline for data protection policie

Output:

- User identity verified (**Admin_Staff_Group**)
- Device posture verified (**disk encryption enabled, system fully patched**)
- Granular file access permissions applied (**read/write control**)
- **Data Loss Prevention (DLP)** policies actively enforced

Scenario 4: IT Administrator Secure Access to Server Management Interfaces

A system administrator requires Remote Desktop Protocol (RDP) access to manage critical Windows servers within the organization's data center. Through **Zscaler Private Access (ZPA)**, the administrator connects securely to specific servers without exposing RDP ports to the internet. Administrative sessions are also recorded to ensure compliance and auditing.

Output:

- User identity verified (**IT_Admin_Group**)
- Privileged access workflow initiated (**approval required**)
- Session monitoring and recording enabled
- Micro-tunnel created to the **specific server IP and port only**

Scenario 5: Visiting Professor Access to Library Resources

A visiting professor from a partner institution requires temporary access to digital archives hosted on the university's internal library application server. Using **Zscaler Private Access (ZPA)**, the professor is granted secure, limited access without being connected to the broader internal network.

Output:

- User identity verified (**Visiting_Faculty_Group**)
- Just-in-time access granted (**8-hour session duration**)
- Connection restricted to the **Library Application Server**
- Full network segmentation maintained to protect other systems

Stage – 1

Title of the Project

Replace and Modernize Legacy VPN Architectures with a Cloud-Native Zero Trust Solution Using Zscaler to Reduce Attack Surface and Prevent Lateral Movement

Overview

This project focuses on transforming the organization's remote access and network security infrastructure by replacing the existing legacy Virtual Private Network (VPN) system with a cloud-native Zero Trust architecture provided by Zscaler. Traditional VPN solutions operate on a perimeter-based security model often referred to as the "castle-and-moat" approach, where users are granted broad network access once they successfully connect. While this model was effective in earlier network environments, it creates major security risks in modern distributed infrastructures.

With legacy VPN architectures, users who connect to the network are often trusted by default and gain access to multiple internal resources. This broad access significantly increases the organization's attack surface. If a malicious actor compromises a single user credential, they may be able to move laterally across the network and access sensitive systems. In addition, maintaining VPN appliances requires continuous management, hardware upgrades, patching, and scaling efforts, which increases operational complexity and cost. The routing of traffic through centralized data centers also leads to performance issues and a poor user experience for remote employees.

To address these challenges, the organization will implement Zscaler Private Access (ZPA), a Zero Trust Network Access solution designed to secure application connectivity without exposing the internal network. ZPA follows the Zero Trust principle of **"never trust, always verify"**, ensuring that access decisions are continuously validated based on user identity, device posture, and security context.

Unlike traditional VPNs, ZPA connects users directly to specific applications rather than granting them full network access. Internal applications remain completely invisible to the public internet because they are not exposed through public IP addresses or open ports. When a user requests access, ZPA verifies their identity using integrations with identity providers

such as Microsoft Azure Active Directory and evaluates device security posture before establishing a secure encrypted micro-tunnel between the user and the authorized application. This micro-segmented architecture ensures that users can only access the applications they are permitted to use, preventing unauthorized discovery of other internal systems. As a result, the risk of lateral movement is effectively eliminated, since attackers cannot scan the network or pivot to other resources even if a device or account is compromised.

The expected outcomes of this modernization initiative include a significantly reduced attack surface, stronger protection against advanced cyber threats, and improved visibility into user access activities. Additionally, moving to a cloud-native platform eliminates the need for complex VPN hardware infrastructure and simplifies network management through a centralized cloud console.

Overall, this project will enhance the organization's security posture while improving performance and accessibility for remote and hybrid workers. By implementing a Zero Trust architecture with Zscaler, the organization will establish a scalable, secure, and future-ready access framework that supports evolving business and security requirements.

List of Vulnerability:

S.No	**Vulnerability Name**	**CWE Number/ Description**
1.	Improper Sanitization of File Paths	**CWE-284** – Improper Access Control
2.	Invalid Certificate	**CWE-295** – Improper Certificate Validation
3.	Missing X-Frame- Options Header	**CWE-1021** – Improper Restriction of Rendered UI Layers or Frames
4.	X-Content-Type-Options Header Missing	**CWE-918** – Server-Side Request Forgery (SSRF)

5.	Drupal Ajax API shows JSONP not disabled by default	**CWE-937, CWE-1035** – OWASP Top 10 (Using Components with Known Vulnerabilities)
6.	Drupal API Vulnerability	**CWE-20** – Improper Input Validation
7.	Improper API Filtration	**CWE-79** – Improper Neutralization of Input During Web Page Generation (Cross-Site Scripting)
8.	Denial of Service	**CWE-400** – Uncontrolled Resource Consumption
9.	TLS Version 1.0 Protocol Detection	**CWE-327** – Use of a Broken or Risky Cryptographic Algorithm
10.	web.config File Information Disclosure	**CWE-497** – Exposure of Sensitive System Information to an Unauthorized Control Sphere

Main Website:

s.no	Vulnerability name	CWE No
1.	SL Medium Strength Cipher Suites Supported (SWEET32)	CWE-200: Exposure of Sensitive Information to an Unauthorised Actor
2.	Cookie SERVERID created without secure flag	CWE-79: Improper Neutralisation of Input During Web Page Generation
3.	X-Content-Type Options Header Missing	CWE-918: Server-Side Request Forgery (SSRF)
4.	Denial of Service	CWE -400: Uncontrolled Resource Consumption
5.	OS Identification	CWE-200: Exposure of Sensitive Information to an Unauthorised Actor

Main Website:

s.no	Vulnerability name	CWE No
1.	SL Medium Strength Cipher Suites Supported (SWEET32)	CWE-200: Exposure of Sensitive Information to an Unauthorised Actor
2.	Cookie SERVERID created without secure flag	CWE-79: Improper Neutralisation of Input During Web Page Generation
3.	X-Content-Type Options Header Missing	CWE-918: Server-Side Request Forgery (SSRF)
4.	Denial of Service	CWE -400: Uncontrolled Resource Consumption
5.	OS Identification	CWE-200: Exposure of Sensitive Information to an Unauthorised Actor

Report:

1. Vulnerability Name: Improper Access Control

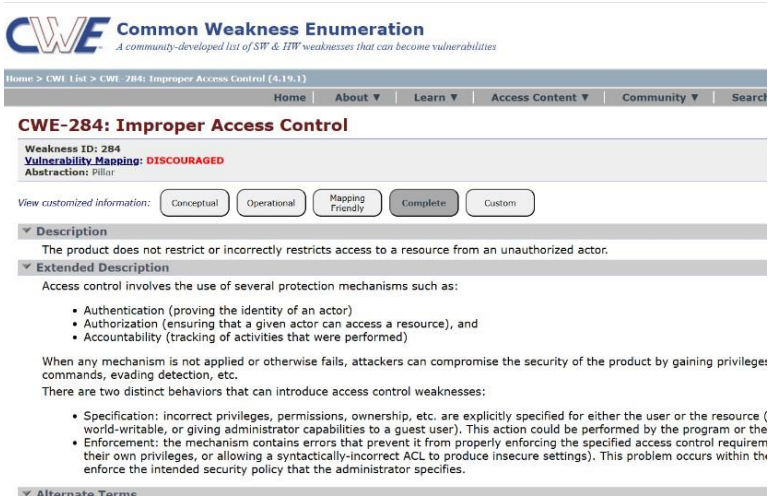
CWE-284: Improper Access Control

OWASP Category: A01:2021-Broken Access Control

Description: Improper Access Control occurs when an application does not correctly enforce authorization checks, allowing users to access resources or perform actions beyond their assigned privileges. In this case, the application fails to properly validate user roles and permissions before granting access to restricted functionality. As a result, unauthorized users may directly access sensitive endpoints or resources that should only be available to privileged users. The vulnerable endpoint can be accessed directly via the following path: **https://example.com/admin/dashboard**

Business Impact: This vulnerability could allow unauthorized users to access restricted functionality or sensitive data within the application. Exploitation may lead to privilege escalation, exposure of confidential information, modification or deletion of critical data, and unauthorized administrative actions. Such incidents can result in financial loss, reputational damage, and potential regulatory compliance violations for the organization.

Vulnerability Path: https://example.com/admin/dashboard



Steps to Reproduce

1. Log in to the application with a **low-privileged user account**.
2. Open a browser or intercept the request using **Burp Suite**.
3. Directly navigate to restricted end point .

https://example.com/admin/dashboard

4. Observe that the application loads the **admin dashboard or restricted resource**

without verifying the user's role or permissions.

5. This confirms that the application does not properly enforce access control.

Solution

- Implement **server-side authorization checks** for all sensitive endpoints.
- Enforce **Role-Based Access Control (RBAC)** to ensure only authorized roles can access restricted resources.
- Validate **user permissions before processing requests** for sensitive actions.
- Avoid relying on **client-side validation for access control**.
- Perform **regular security testing and code reviews** to identify authorization flaws.
- Log and monitor unauthorized access attempts for security auditing.

2. Vulnerability name: Invalid Certificate

CWE: 295

OWASP Category: A07:2021 – Identification and Authentication Failures

Description: Improper Certificate Validation is a security vulnerability that occurs when an application fails to properly verify the authenticity of an SSL/TLS certificate during secure communication. Digital certificates are used to ensure that the client is communicating with a legitimate server and that the transmitted data is encrypted. If the application does not validate the certificate correctly—such as ignoring certificate authority verification, expiration dates, or hostname matching—it may trust malicious or fake certificates. As a result, attackers can impersonate legitimate servers and intercept or manipulate sensitive communication between systems.

Business Impact: Improper certificate validation can expose organizations to significant security and financial risks. Attackers can perform Man-in-the-Middle (MITM) attacks, allowing them to intercept confidential information such as user credentials, personal data, or financial transactions. This can lead to data breaches, loss of customer trust, regulatory penalties, and reputational damage for the organization. In industries such as banking, healthcare, and e-commerce, this vulnerability may also disrupt operations and violate security compliance standards, resulting in serious business consequences.

Vulnerability Path Link

MITRE Corporation Official CWE Link: https://cwe.mitre.org/data/definitions/295.html

Reproduce the Vulnerability:

Install a network interception tool such as Burp Suite or MITM Proxy. Configure the application to send HTTPS requests through the proxy. Use a self-signed certificate in the proxy tool.

Run the application and capture the network traffic.

If the application accepts the connection without verifying the certificate properly, the traffic can be intercepted successfully.

This confirms that the application does not properly validate SSL/TLS certificates and is vulnerable to CWE-295.

Solution:

- Implement proper SSL/TLS certificate validation in the application.
- Verify that certificates are issued by a trusted Certificate Authority (CA).
- Check certificate expiration and validity dates.
- Validate that the hostname matches the certificate domain.
- Enable certificate revocation checks (CRL or OCSP).
- Avoid disabling certificate verification in production code.
- Implement certificate pinning to ensure the correct certificate is used.
- Regularly update security libraries and TLS configurations.

3.Vulnerability Name: Missing X-Frame-Options Header

CWE-1021: Design Improper Restriction of Rendered UI Layers or Frames OWASP Category: A04:2021-Insecure Design

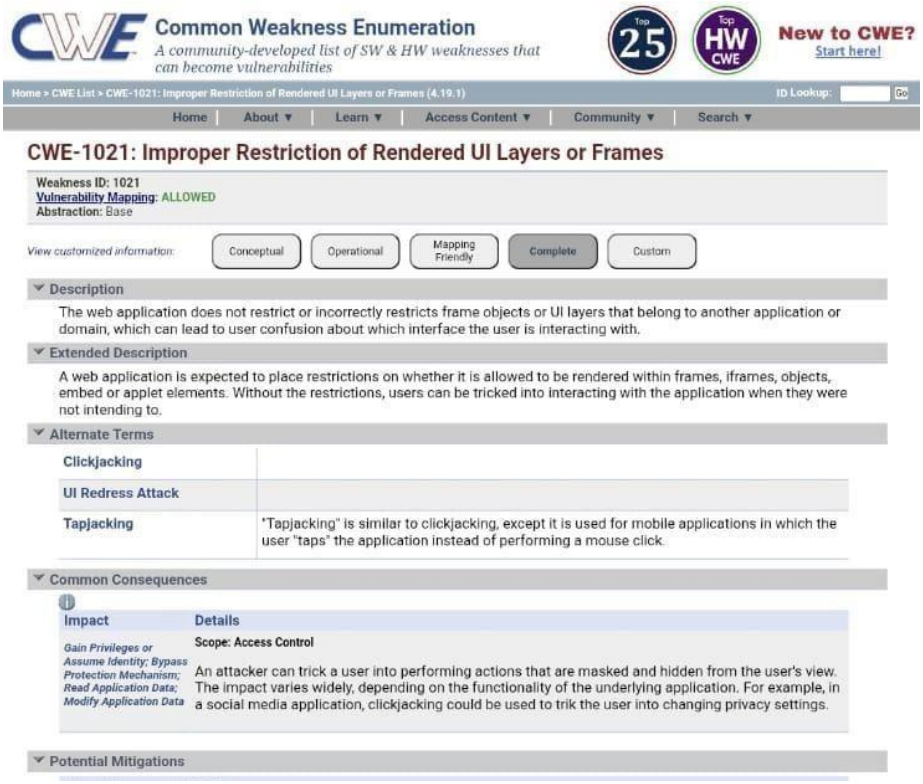
Description: Improper Restriction of Rendered UI Layers or Frames is a vulnerability that occurs when a web application does not properly restrict its pages from being displayed inside frames, iframes, or UI layers on another website. Because of this weakness, attackers can embed the legitimate webpage inside a malicious webpage. Users may unknowingly interact with hidden elements of the original website. This attack technique is commonly known as clickjacking, where attackers manipulate the interface to trick users into performing unintended actions such as clicking buttons, approving requests, or submitting information.

Business Impact: This vulnerability can create serious security risks for organizations. Attackers can trick users into performing sensitive actions like changing account settings, approving financial transactions, or exposing confidential information. In applications such as banking systems, e- commerce platforms, and social media websites, this can result in financial loss, unauthorized account access, data leakage, and misuse of user privileges. It can also damage the company's reputation and reduce customer trust.

Vulnerability Path Link:

MITRE Corporation Official CWE Link:

https://cwe.mitre.org/data/definitions/1021.html



Common Weakness Enumeration

A community-developed list of SW & HW weaknesses that can become vulnerabilities

Top 25 | Top HW CWE | New to CWE? Start here!

Home > CWE List > CWE-1021: Improper Restriction of Rendered UI Layers or Frames (4.19.1) | ID Lookup: Go

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

CWE-1021: Improper Restriction of Rendered UI Layers or Frames

Weakness ID: 1021
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The web application does not restrict or incorrectly restricts frame objects or UI layers that belong to another application or domain, which can lead to user confusion about which interface the user is interacting with.

Extended Description

A web application is expected to place restrictions on whether it is allowed to be rendered within frames, iframes, objects, embed or applet elements. Without the restrictions, users can be tricked into interacting with the application when they were not intending to.

Alternate Terms

Clickjacking	
UI Redress Attack	
Tapjacking	"Tapjacking" is similar to clickjacking, except it is used for mobile applications in which the user "taps" the application instead of performing a mouse click.

Common Consequences

Impact	Details
Gain Privileges or Assume Identity; Bypass Protection Mechanism; Read Application Data; Modify Application Data	**Scope: Access Control** An attacker can trick a user into performing actions that are masked and hidden from the user's view. The impact varies widely, depending on the functionality of the underlying application. For example, in a social media application, clickjacking could be used to trik the user into changing privacy settings.

Potential Mitigations

Reproduce the Vulnerability:

- Choose a target web application page that allows framing.
- Create a malicious HTML page.
- Embed the target website inside an iframe.
- Place misleading buttons or transparent overlays above the iframe.
- Send the malicious page link to a user.
- When the user clicks the visible button, they unknowingly interact with the hidden legitimate page.

If the action is executed successfully, the application is vulnerable to clickjacking (CWE-1021).

Example test code:

Html Copy code

```
<html>

<body>

<h2>Click here to win a prize</h2>

<iframe src="https://targetwebsite.com" width="800" height="600"></iframe>

</body>

</html>
```

Solution:

- Use X-Frame-Options header (DENY or SAMEORIGIN).
- Implement Content Security Policy (CSP) with the frame-ancestors directive.
- Restrict which domains are allowed to embed the webpage.
- Use frame-busting scripts to prevent framing.
- Perform regular security testing for clickjacking vulnerabilities.

4.Vulnerability Name: X-Content-Type Options Header Missing

CWE -918: Server-Side Request Forgery (SSRF)

OWASP Category: A10:2021 – Server-Side Request Forgery (SSRF)

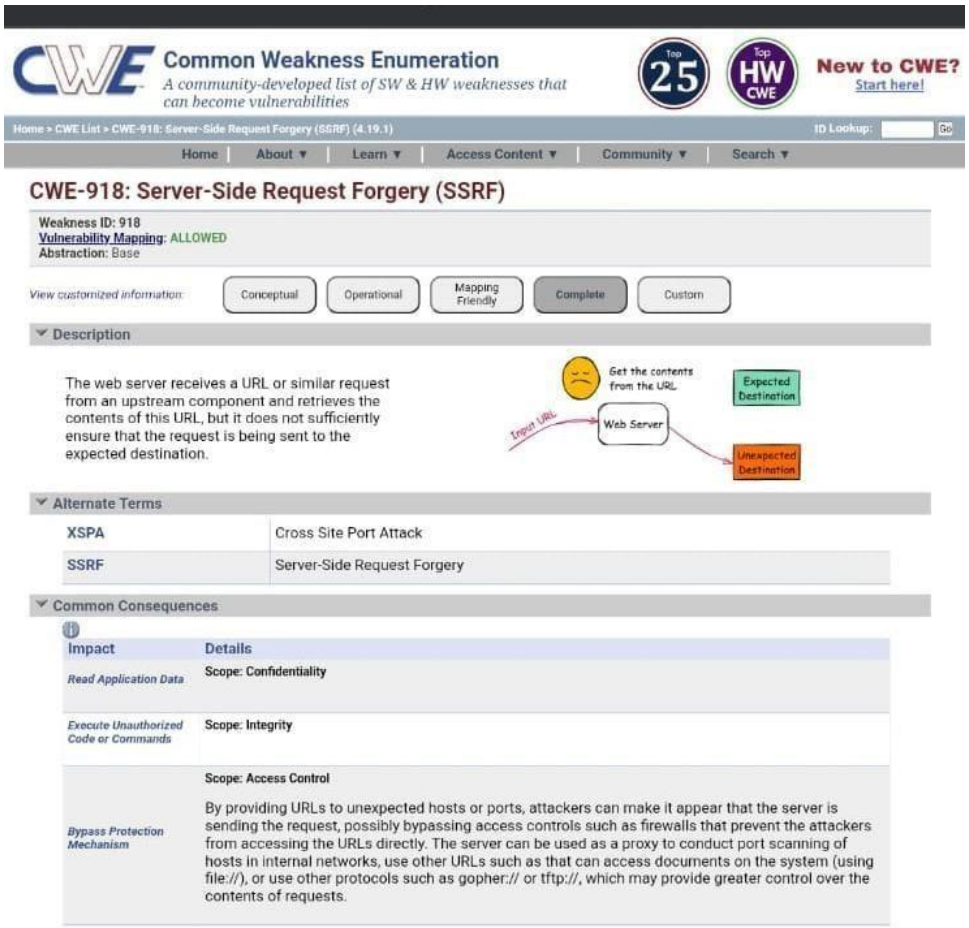
Description: Server-Side Request Forgery (SSRF) is a vulnerability that occurs when a web server accepts a URL from user input and fetches the content from that URL without proper validation. In this situation, the attacker can manipulate the server to send requests to unintended destinations such as internal systems or restricted resources. Because the request is made by the server itself, it may bypass firewall rules or access controls. This allows attackers to interact with internal services that are normally not accessible from outside the network.

Business Impact: SSRF can cause serious security risks to organizations because attackers may access internal systems, confidential data, or restricted services through the vulnerable server. They can use the server to scan internal networks, retrieve sensitive information, or execute unauthorized requests. In cloud environments, attackers may even access metadata services and obtain credentials. This can lead to data breaches, system compromise, unauthorized access, and financial loss, which can damage the organization's reputation and trust.

Vulnerability Path Link:

MITRE Corporation Official CWE Reference:

https://cwe.mitre.org/data/definitions/918.html



Common Weakness Enumeration

A community-developed list of SW & HW weaknesses that can become vulnerabilities

Top 25 | Top HW CWE | New to CWE? Start here!

Home > CWE List > CWE-918: Server-Side Request Forgery (SSRF) (4.19.1) | ID Lookup: Go

Home | About ▾ | Learn ▾ | Access Content ▾ | Community ▾ | Search ▾

CWE-918: Server-Side Request Forgery (SSRF)

Weakness ID: 918
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The web server receives a URL or similar request from an upstream component and retrieves the contents of this URL, but it does not sufficiently ensure that the request is being sent to the expected destination.

Alternate Terms

XSPA	Cross Site Port Attack
SSRF	Server-Side Request Forgery

Common Consequences

Impact	Details
Read Application Data	Scope: Confidentiality
Execute Unauthorized Code or Commands	Scope: Integrity
Bypass Protection Mechanism	Scope: Access Control By providing URLs to unexpected hosts or ports, attackers can make it appear that the server is sending the request, possibly bypassing access controls such as firewalls that prevent the attackers from accessing the URLs directly. The server can be used as a proxy to conduct port scanning of hosts in internal networks, use other URLs such as that can access documents on the system (using file://), or use other protocols such as gopher:// or tftp://, which may provide greater control over the contents of requests.

Reproduce the Vulnerability:

- Identify a web application that accepts a URL as user input.
- Enter a normal external URL and confirm the server retrieves the content.
- Modify the input URL to point to an internal resource (example: http://127.0.0.1 or http://localhost).
- Send the request to the server.
- If the server fetches the internal resource and returns the response, the application is vulnerable.
- Attackers can also attempt requests to internal IP ranges or sensitive services to confirm the SSRF vulnerability.

Example vulnerable code:

```
$url = $_GET['url'];

$response = file_get_contents($url); echo $response;
```

Solution:

- Validate and sanitize all user-supplied URLs.
- Restrict requests to trusted domains only (allowlist).
- Block requests to internal IP addresses and localhost.
- Disable unnecessary protocols such as file://, ftp://, gopher://.
- Implement network-level protections such as firewalls and request filtering.
- Use secure libraries that enforce URL validation and request restrictions.

5. Vulnerability Name: Drupal Ajax API shows JSONP not disabled by default

CWE-937,1035: OWASP Top Ten 2013,2017 Category A9 - Using Components with Known Vulnerabilities

OWASP Category: A06:2021-Vulnerable and Outdated Components

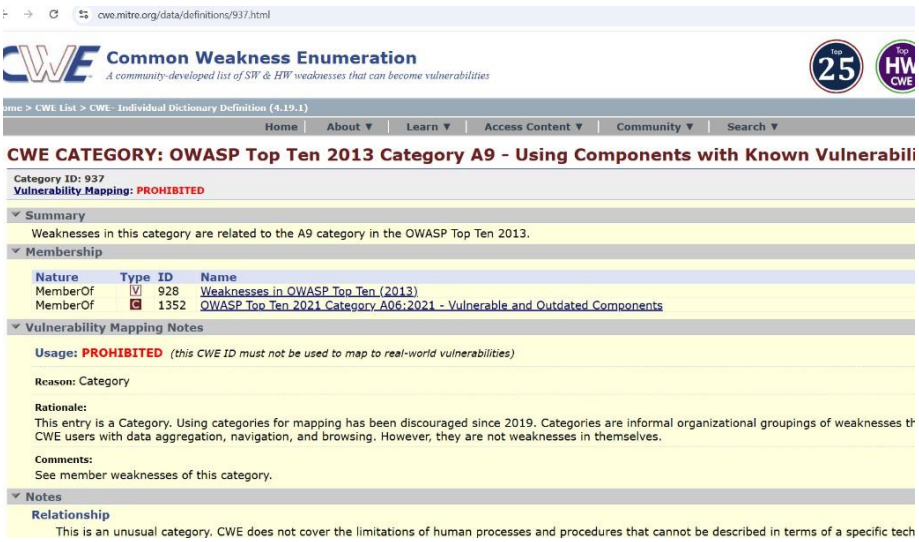
Description: The application uses outdated or vulnerable third-party components that contain known security vulnerabilities. These components may include libraries, frameworks, plugins, or other software modules that are no longer supported or have publicly disclosed vulnerabilities. Attackers can exploit these known weaknesses to compromise the security of the application, potentially gaining unauthorized access, executing malicious code, or exposing sensitive data. The vulnerable component was identified within the application resources accessible via the following path:

https://example.com/assets/js/jquery-1.8.3.min.js

Business Impact: Using vulnerable and outdated components exposes the application to publicly known exploits that attackers can easily leverage. If successfully exploited, attackers may execute malicious scripts, bypass security controls, access sensitive information, or compromise the entire application environment. This could lead to data breaches, system compromise, service disruption, regulatory penalties, and reputational damage for the organization.

Vulnerable Path

https://example.com/assets/js/jquery-1.8.3.min.js



Steps to Reproduce:

- Open the target web application in a browser.
- View the page source or use developer tools.
- Identify the JavaScript library loaded by the application: https://example.com/assets/js/jquery-1.8.3.min.js
- Verify the version of the component being used.
- Search public vulnerability databases and confirm that this version contains known vulnerabilities.
- Observe that the application is running an **outdated and vulnerable component**.

Solution:

- Update all third-party libraries and frameworks to their **latest secure versions**.
- Implement a **dependency management process** to regularly monitor component updates.
- Use automated tools to detect vulnerable components (e.g., dependency scanners).
- Remove **unused or unnecessary libraries** from the application.
- Subscribe to **security advisories** for the components used in the application.
- Perform **regular security audits and patch management**.

6.Vulnerability Name: Drupal Api Vulnerability CWE-20: Improper Input Validation

OWASP Category: A03:2021 – Injection

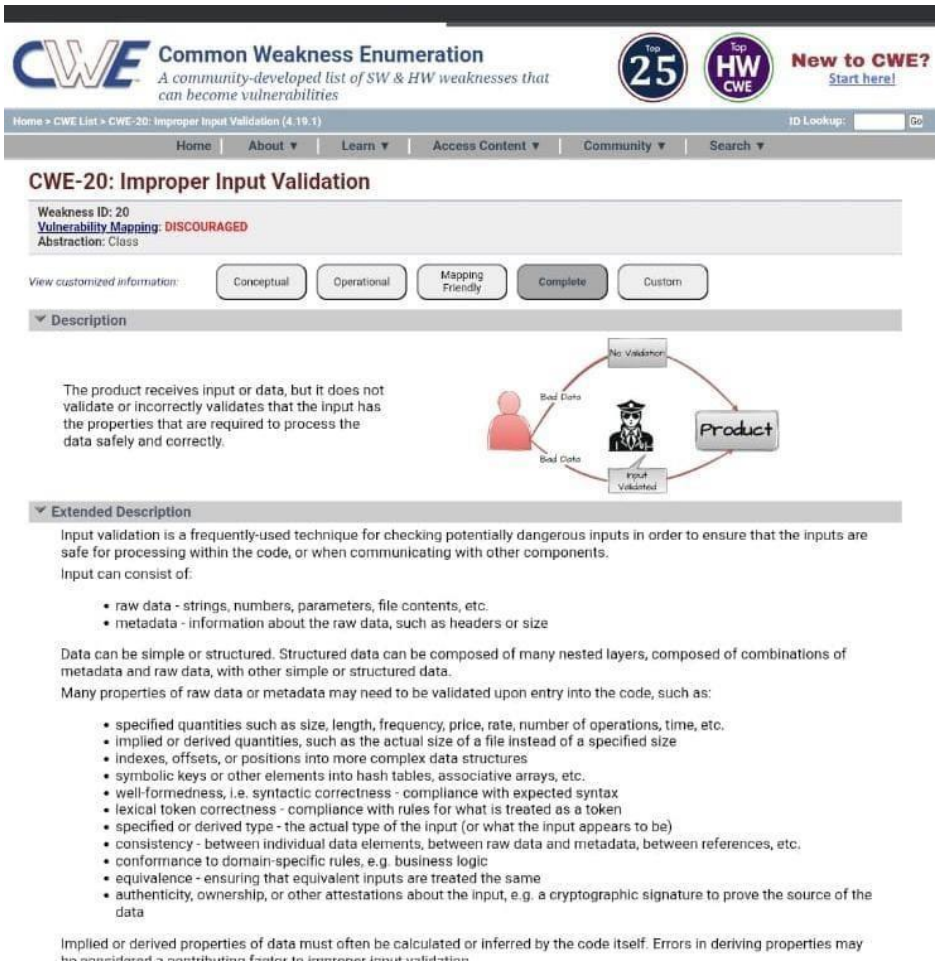
Description: Improper Input Validation is a vulnerability that occurs when a software application receives input from users or external sources but fails to properly validate or sanitize that input. Input validation is important to ensure that the data entered into the system follows the expected format, type, and size. If validation is missing or incorrect, attackers can send malicious or unexpected input that may cause system errors, bypass security controls, or execute harmful actions within the application.

Business Impact: Improper input validation can create serious security risks for organizations. Attackers may exploit the vulnerability to inject malicious data, access restricted information, manipulate system behavior, or crash the application. This can result in data breaches, unauthorized access, service disruption, and financial loss. In many cases, this vulnerability is the root cause of other attacks such as SQL injection, command injection, and cross-site scripting, which can further damage the organization's systems and reputation.

Vulnerability Path Link:

MITRE Corporation Official CWE Reference:

https://cwe.mitre.org/data/definitions/20.html



Common Weakness Enumeration

A community-developed list of SW & HW weaknesses that can become vulnerabilities

Top 25 | Top HW CWE | New to CWE? Start here!

Home > CWE List > CWE-20: Improper Input Validation (4.19.1) | ID Lookup:

Home | About | Learn | Access Content | Community | Search

CWE-20: Improper Input Validation

Weakness ID: 20
Vulnerability Mapping: DISCOURAGED
Abstraction: Class

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product receives input or data, but it does not validate or incorrectly validates that the input has the properties that are required to process the data safely and correctly.

Extended Description

Input validation is a frequently-used technique for checking potentially dangerous inputs in order to ensure that the inputs are safe for processing within the code, or when communicating with other components.

Input can consist of:

- raw data - strings, numbers, parameters, file contents, etc.
- metadata - information about the raw data, such as headers or size

Data can be simple or structured. Structured data can be composed of many nested layers, composed of combinations of metadata and raw data, with other simple or structured data.

Many properties of raw data or metadata may need to be validated upon entry into the code, such as:

- specified quantities such as size, length, frequency, price, rate, number of operations, time, etc.
- implied or derived quantities, such as the actual size of a file instead of a specified size
- indexes, offsets, or positions into more complex data structures
- symbolic keys or other elements into hash tables, associative arrays, etc.
- well-formedness, i.e. syntactic correctness - compliance with expected syntax
- lexical token correctness - compliance with rules for what is treated as a token
- specified or derived type - the actual type of the input (or what the input appears to be)
- consistency - between individual data elements, between raw data and metadata, between references, etc.
- conformance to domain-specific rules, e.g. business logic
- equivalence - ensuring that equivalent inputs are treated the same
- authenticity, ownership, or other attestations about the input, e.g. a cryptographic signature to prove the source of the data

Implied or derived properties of data must often be calculated or inferred by the code itself. Errors in deriving properties may

Reproduce the Vulnerability:

- Identify an input field in the application (login form, search box, file upload, etc.).
- Enter normal valid input and observe the application response.

- Enter unexpected or malicious input such as special characters or scripts (example: ' OR 1=1 -- or <script>alert(1)</script>).
- Submit the input to the application.
- If the application processes the input without validation and behaves abnormally, the vulnerability exists.
- This confirms that the system does not properly validate user input.

Example vulnerable code:

```
$username = $_GET['username'];

echo "Welcome ". $username;
```

Solution:

- Validate all user inputs before processing.
- Use input allowlists to accept only expected data formats.
- Sanitize user input to remove harmful characters.
- Use parameterized queries to prevent injection attacks.
- Implement server-side validation in addition to client-side checks.
- Apply secure coding practices and perform regular security testing.

7.Vulnerability Name: Improper API Filtration

CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')

OWASP Category: A07-2017: Cross-site Scripting (XSS)

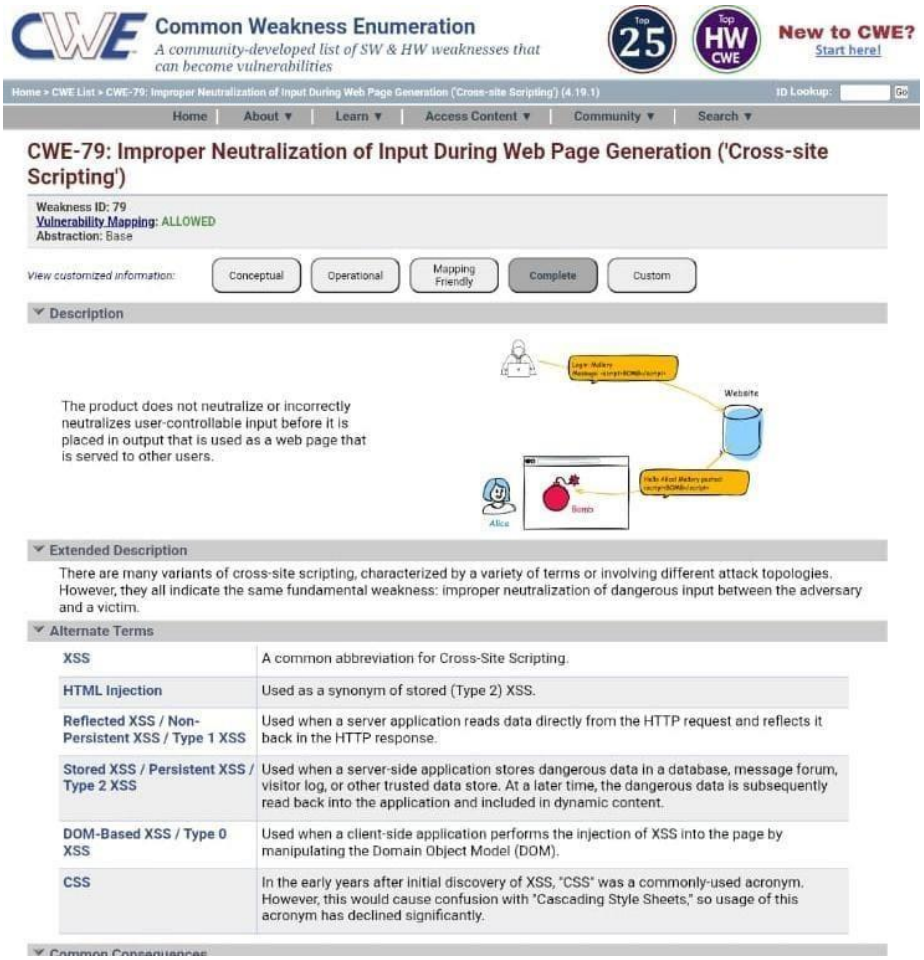
Description: Improper Neutralization of Input During Web Page Generation (Cross-Site Scripting) is a vulnerability that occurs when a web application accepts user input and includes it in a webpage without properly validating or encoding it. Because of this weakness, attackers can inject malicious scripts into web pages that are executed in the browsers of other users. These scripts can run with the same permissions as the website, allowing attackers to manipulate the webpage or steal sensitive information.

Business Impact: Cross-Site Scripting (XSS) can cause serious security problems for organizations and users. Attackers can steal session cookies, login credentials, or personal information from users. They may also redirect users to malicious websites, perform unauthorized actions on behalf of users, or modify the content of the webpage. This can lead to account hijacking, data theft, loss of customer trust, and damage to the organization's reputation.

Vulnerability Path Link:

MITRE Corporation

Official CWE Reference: https://cwe.mitre.org/data/definitions/79.html



Reproduce the Vulnerability:

- Identify an input field in the web application such as a comment box or search field.
- Enter normal input and observe how it appears on the webpage.
- Enter a script payload such as <script>alert("XSS")</script>.
- Submit the input to the application.
- If the script executes in the browser (for example showing an alert box), the application is vulnerable to XSS.
- This shows that the application does not properly sanitize or encode user input.

Example vulnerable code:

```
$name = $_GET['name']; echo "Hello " . $name;
```

Solution:

- Validate and sanitize all user inputs before displaying them.
- Encode output data using HTML encoding.
- Use Content Security Policy (CSP) to restrict script execution.
- Use secure frameworks that automatically prevent XSS.
- Avoid directly inserting user input into HTML or JavaScript.
- Perform regular security testing to detect XSS vulnerabilities.

8.Vulnerability Name: Denial of Service (DoS)

CWE: CWE-400 – Uncontrolled Resource Consumption OWASP Category: Availability / Resource Exhaustion

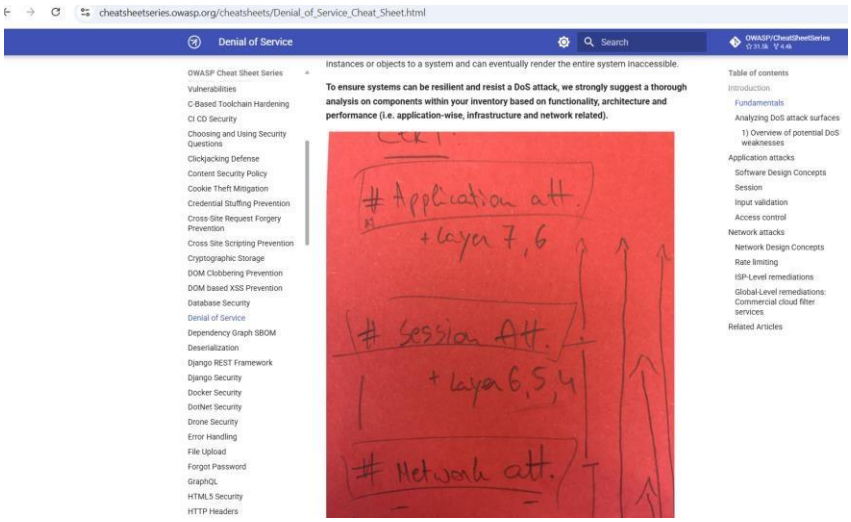
Description: A Denial of Service (DoS) attack aims to disrupt the normal functioning of a system, application, or network by making it unavailable to legitimate users. This type of attack typically occurs when an attacker overwhelms a target with a large volume of requests or exploits weaknesses in how the system handles resources. As the number of incoming requests increases beyond the system's capacity, the server may become slow, unresponsive,

or completely unavailable. Attackers may exploit vulnerabilities in network protocols, application logic, or resource management mechanisms to trigger such conditions. In some situations, attackers may also attempt to execute malicious code during the attack, potentially gaining unauthorized access to sensitive information or server commands. Overall, DoS attacks significantly degrade service availability by causing long response delays, service interruptions, and performance degradation for legitimate users.

Business Impact: If successfully exploited, this vulnerability can severely affect business operations by overwhelming the system with excessive resource demands. The targeted application or server may experience performance degradation, resulting in slow response times or complete system failure. Critical resources such as CPU, memory, and network bandwidth may become exhausted, preventing legitimate users from accessing services. In extreme cases, system crashes may occur, potentially leading to service downtime and data loss. These disruptions can negatively impact business productivity, customer satisfaction, and organizational reputation. Furthermore, prolonged outages may result in financial losses and possible violations of regulatory or service level agreement (SLA) requirements.

Steps to Reproduce:

An attacker may target open service ports such as **port 80 (HTTP)** to generate a large volume of malicious or repeated requests. By exploiting vulnerabilities through techniques such as automated traffic flooding, SQL injection attempts, cross-site request forgeries, or distributed denial-of-service (DDoS) methods, the attacker can overwhelm the server and cause service disruption.



9.Vulnerability Name: TLS Version 1.0 Protocol Detection

CWE: CWE-327 – Use of a Broken or Risky Cryptographic Algorithm OWASP Category: Cryptographic Failures

Description: This vulnerability occurs when a server supports **Transport Layer Security (TLS) version 1.0**, which is considered outdated and insecure by modern security standards. Older encryption protocols such as TLS 1.0 contain known weaknesses that attackers can exploit to compromise the confidentiality and integrity of data transmitted between a client and the server. Because TLS 1.0 relies on weaker cryptographic algorithms and outdated security mechanisms, it is vulnerable to several attacks that may allow interception or manipulation of sensitive communication. Modern security frameworks and compliance standards recommend disabling TLS 1.0 and using more secure protocols such as TLS 1.2 or TLS 1.3 to ensure strong encryption and secure data transmission.

Business Impact: If TLS 1.0 remains enabled, attackers may exploit its known vulnerabilities to intercept sensitive information transmitted over the network. This may include login credentials, personal data, financial information, or other confidential communications. Such exploitation can lead to data breaches, unauthorized access to systems, and loss of customer trust. Additionally, the use of outdated cryptographic protocols may cause organizations to fail compliance requirements for security standards such as PCI-DSS or other regulatory frameworks. This could result in financial penalties, reputational damage, and operational risks.

Steps to Reproduce:

- Perform a vulnerability scan using tools such as SSL/TLS scanners or security assessment tools.
- Identify supported SSL/TLS protocols on the target server.
- Observe that the server allows connections using **TLS version 1.0**.
- Confirm that the outdated protocol is enabled and accepted during the SSL/TLS handshake process.

10.Vulnerability Name: web. config File Information Disclosure

CWE-497: Exposure of Sensitive System Information to an Unauthorized Control Sphere
OWASP Category: A3:2017-Sensitive Data Exposure

Description: This vulnerability occurs when the **web.config** file of a web application is accessible to unauthorized users. The **web.config** file is commonly used in web applications built on Microsoft technologies and contains important configuration settings such as database connection strings, authentication details, application settings, and server configurations. If this file is improperly configured or publicly accessible, attackers may retrieve sensitive information that can help them understand the internal structure of the application. This exposure can assist attackers in planning further attacks, identifying system weaknesses, or gaining unauthorized access to backend systems.

Business Impact: If an attacker successfully accesses the **web.config** file, sensitive configuration data such as database credentials, API keys, or internal server paths may be exposed. This information could allow attackers to compromise the application, access confidential data, or manipulate backend services. In severe cases, it may lead to unauthorized database access, data leakage, or complete system compromise. Such incidents can result in financial loss, reputational damage, and potential violations of security compliance requirements.

Steps to Reproduce:

- Access the target website through a browser or vulnerability scanning tool.
- Attempt to directly navigate to the **/web.config** file in the web directory.
- If the server is misconfigured, the configuration file may be downloaded or displayed in plain text.
- Review the file contents to identify sensitive configuration details.

STAGE 2

Overview :-

Nessus is a vulnerability scanner developed by Tenable, Inc. It is a remote scanner, meaning that it does not need to be installed on the target host to scan it. Nessus works by sending a variety of probes to the target host in order to identify vulnerabilities. These probes can include network traffic, operating system commands, and application requests.

Nessus uses a plugin-based architecture. Plugins are small pieces of code that are designed to identify specific vulnerabilities. There are over 1200 plugins available for Nessus, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

When Nessus scans a host, it first uses a discovery plugin to identify the operating system and services running on the host. Once the host has been discovered, Nessus runs a series of plugins to test for vulnerabilities. For each vulnerability that Nessus finds, it provides a detailed report that includes the severity of the vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to run scans on a schedule or manually.

Here is a step-by-step explanation of how Nessus works:

1. Nessus connects to the target host using a variety of protocols, including TCP, UDP, and ICMP.

2. Nessus sends a series of probes to the target host in order to identify its operating system and services.

3. Nessus runs a series of plugins to test for vulnerabilities.

4. Nessus generates a report that includes the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus is a valuable tool for security professionals who need to identify and remediate vulnerabilities in their networks. It is easy to use and provides comprehensive reports that can be used to prioritise remediation efforts.

Here are some of the benefits of using Nessus:

- Comprehensive vulnerability coverage: Nessus has over 1200 plugins available, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

- Easy to use: Nessus has a user-friendly interface that makes it easy to configure and run scans.

- Comprehensive reporting: Nessus provides detailed reports that include the severity of each vulnerability,the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

- Scalability: Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications.

- Flexibility: Nessus can be configured to run scans on a schedule or manually.

Nessus is a powerful tool that can be used to improve the security of any network. It is a valuable asset for any security professional.

Target website :- http://testfire.net/

Target ip address:- 65.61.137.117

List of vulnerability:-

s.no	Vulnerability name	Severity	Plugins
1	**TLS Version 1.0 Protocol Detection**	Medium	104743
2	**HTTP Server Type and Version**	Info	10107
3	**SSL Perfect Forward Secrecy Cipher Suites Supported**	Info	57041
4	**SSL / TLS Versions Supported**	Info	56984
5	**Additional DNS Hostnames**	Info	46180
6	**Device Type**	Info	54615
7	**Web Server No 404 Error Code Check**	Info	10386
8	**TCP/IP Timestamps Supported**	Info	25220
9	**OS Identification**	Info	11936
10	**Open Port Re-check**	Info	10919

REPORT: -

Vulnerability Name: - 104743 - TLS Version 1.0 Protocol Detection: - MEDIUM

Plugin: - 104743

Port: - 443

Description :- The remote service accepts connections encrypted using TLS 1.0. TLS 1.0 has a number of cryptographic design flaws. Modern implementations of TLS 1.0 mitigate these problems, but newer versions of TLS like 1.2 and 1.3 are designed against these flaws and should be used whenever possible.

As of March 31, 2020, Endpoints that aren't enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

PCI DSS v3.2 requires that TLS 1.0 be disabled entirely by June 30, 2018, except for POS POI terminals (and the SSL/TLS termination points to which they connect) that can be verified as not being susceptible to any known exploits.

Solution:- Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.

Business Impact :- The detection of Transport Layer Security 1.0 indicates that the system supports an outdated encryption protocol with known cryptographic weaknesses. Continued use of this protocol increases the risk of sensitive data exposure because attackers may exploit vulnerabilities to intercept or decrypt communications, potentially leading to unauthorized access to credentials, customer information, or financial data. It also creates compliance risks, as security standards such as Payment Card Industry Data Security Standard no longer permit the use of TLS 1.0 for protecting payment or sensitive information. Exploitation of this weakness could enable man-in-the-middle attacks, allowing attackers to intercept or manipulate data in transit. If compromised, the organization could face regulatory penalties, financial losses, service disruptions, and reputational damage due to reduced customer trust and negative public perception. Additionally, maintaining support for legacy protocols limits the organization's ability to implement stronger security protections available in modern versions like Transport Layer Security 1.2 and Transport Layer Security 1.3.

2) **Vulnerability Name: -** 157288 - TLS HTTP Server Type and Version : - Info

Plugin: - 10107

Port: - 80

Description : This plugin attempts to determine the type and the version of the remote web server.

Solution :- : To fix the TLS/HTTPS Server Type and Version Disclosure vulnerability, configure the web server to hide its software type and version information from HTTPS response header and error pages . For example in Apache , set Server Token Prod and Server Signature Off in the security configuration file in Nginx, disable version disclosure by addind server_tokens off:

Business Impact : The business impact of the TLS/HTTPS server type and version disclosure vulnerabilities is that attackers can identify the extact web server software and version used by organization. This information allows them to search for known vulnerability and exploits related to the specific version increasing the risk of targeted cyberattacks un authorized access, data breaches and service disruption

3) **Vulnerability Name: -** 157288 - TLS SSL Perfect Forward Secrecy Cipher Suites Supported: - Info

Plugin: - 57041

Port: - 443

Description : The remote host supports the use of SSL ciphers that offer Perfect Forward Secrecy (PFS) encryption. These cipher suites ensure that recorded SSL traffic cannot be broken at a future date if the server's private key is compromised.

Solution: - To address the issue of Perfect Forward Secrecy cipher suites being supported ensure that the server is configured to use strong cipher suites that provide forward secrecy while disabling weak or deprecated ciphers. Perfect Forward Secrecy (PFS) itself is a security best practice because it ensures that even if a server’s private key is compromised, previously encrypted communications cannot be decrypted. The recommended solution is to enable modern key-exchange algorithms such as Elliptic Curve Diffie-Hellman Ephemeral or Diffie-

Hellman Ephemeral and prioritize them in the server's cipher configuration. Additionally, ensure the server supports secure protocol versions like Transport Layer Security 1.and Transport Layer Security 1.3 , while disabling outdated protocols such as Secure Sockets Layer and older TLS versions. Regularly update the web server or application server configuration (e.g., Apache, Nginx, IIS) to enforce strong cipher suites, remove weak algorithms (such as static RSA key exchange), and perform periodic security scans to confirm that only secure cipher suites with forward secrecy are enabled. This configuration ensures stronger encryption, protects past sessions, and improves overall transport security for the application.

Business Impact :- The detection of Perfect Forward Secrecy cipher suites indicates that the server supports encryption mechanisms designed to protect past communications even if the server's private key is compromised. From a business perspective, this is generally considered a positive security control, as it reduces the risk of sensitive information such as customer data, credentials, and financial transactions being decrypted in the future. By using secure key-exchange mechanisms like Elliptic Curve Diffie-Hellman Ephemeral and Diffie-Hellman Ephemeral within modern protocols such as Transport Layer Security 1.2 and Transport Layer Security 1.3, the organization improves the confidentiality of data in transit and lowers the likelihood of large-scale data exposure following a key compromise. This strengthens customer trust, helps meet security and compliance expectations, and reduces potential financial, legal, and reputational damage that could arise from intercepted or decrypted communications.

4) **Vulnerability Name**: - 56984 - SSL / TLS Versions Supported : - MEDIUM

Plugin: - 56984

Port: - 443

Description :- This plugin detects which SSL and TLS versions are supported by the remote service for encrypting communications.

Solution :- To remediate issues related to Secure Sockets Layer / Transport Layer Security versions supported, configure the server to disable outdated and insecure protocol versions while allowing only modern, secure versions. Older protocols such as **SSL 2.0**, **SSL 3.0**, **TLS 1.0**, and **TLS 1.1** should be completely disabled because they contain known cryptographic weaknesses that attackers can exploit. The server should be configured to support only secure

and widely accepted protocols such as **TLS 1.2** and **TLS 1.3**. This can be implemented by updating the web server or application server configuration (e.g., Apache, Nginx, IIS, load balancers, or reverse proxies) to explicitly allow only these secure versions and remove support for legacy protocols. Additionally, keep the server software and cryptographic libraries up to date, enforce strong cipher suites, and periodically perform security scans to verify that only secure SSL/TLS versions are enabled. This approach ensures stronger encryption, reduces the risk of protocol-level attacks, and aligns the system with modern security and compliance standards.

Business Impact :- The detection of multiple Secure Sockets Layer / Transport Layer Security versions supported may indicate that the system allows outdated or insecure protocols alongside modern ones. Supporting older versions such as SSL 3.0, TLS 1.0, or TLS 1.1 increases the risk that attackers could exploit known cryptographic weaknesses to intercept, decrypt, or manipulate sensitive data transmitted between users and the server. This could potentially lead to exposure of confidential information such as login credentials, personal data, or financial details. From a business perspective, such weaknesses may result in regulatory and compliance violations, particularly with standards like payment Card Industry Data Security Standard, and could cause financial penalties, legal liabilities, and reputational damage. If exploited, the vulnerability may also disrupt business operations, erode customer trust, and increase the cost of incident response and remediation. Ensuring only modern protocols such as TLS 1.2 and TLS 1.3 are supported helps protect sensitive communications and reduces these business risks.

5) Vulnerability Name: - 46180 - Additional DNS Hostnames: - INFO

Plugin: - 46180

Port: - 443

Description :- Hostnames different from the current hostname have been collected by miscellaneous plugins. Nessus has generated a list of hostnames that point to the remote host. Note that these are only the alternate hostnames for vhosts discovered on a web server.

Different web servers may be hosted on name-based virtual hosts.

Solution :- If you want to test them, re-scan using the special vhost syntax, such as :

www.example.com[192.0.32.10]

Business Impact :- The presence of Domain Name System additional hostnames indicates that multiple domain names or subdomains are associated with the same server or IP address. If these additional hostnames are not properly managed, secured, or monitored, they may expose hidden or legacy services that attackers could target to gain unauthorized access. Unused or forgotten hostnames can increase the attack surface and may contain outdated applications or misconfigured services that are easier to exploit. From a business perspective, this could lead to potential data exposure, unauthorized access to internal resources, or service disruption. It may also result in reputational damage, loss of customer trust, and increased operational costs if a security incident occurs. Proper management and review of all associated hostnames within the Domain Name System infrastructure is important to minimize security risks and ensure that only necessary and secure hostnames are publicly accessible.

6) **Vulnerability Name: -** 54615 - Device Type : - MEDIUM

Plugin: - 54615

Port: - 443

Description :- Based on the remote operating system, it is possible to determine what the remote system type is (eg: a printer, router, general-purpose computer, etc).

Solution :- To address findings related to Device Type, organizations should implement proper asset identification and security configuration for all devices connected to the network. First, ensure that every device is accurately identified and documented in an asset inventory, including its function, operating system, and ownership. Network administrators should restrict unnecessary services, close unused ports, and apply the latest security patches and firmware updates to the device. It is also recommended to enforce strong authentication, enable secure management protocols such as Secure Shell instead of insecure alternatives like Telnet, and implement network segmentation to limit exposure of sensitive systems. Additionally, continuous monitoring, vulnerability scanning, and access control policies should be applied to ensure that only authorized users and systems can interact with the

device. These measures help reduce the risk of unauthorized access, misconfiguration, and potential exploitation of the device within the network environment.

Business Impact :- The identification of a specific Device Type on a network can provide attackers with useful information about the underlying infrastructure and technologies in use. If this information is publicly exposed, threat actors may use it to identify known vulnerabilities associated with that particular device or platform and plan targeted attacks. From a business perspective, exploitation of such weaknesses could lead to unauthorized access, service disruption, or compromise of sensitive data. This may result in operational downtime, financial losses, reputational damage, and increased costs for incident response and remediation. Additionally, exposed infrastructure details can increase the overall attack surface, making it easier for attackers to perform reconnaissance and launch more effective attacks against the organization's systems.

7) Vulnerability Name: - 10386 - Web Server No 404 Error Code Check : - MEDIUM

Plugin: - 10386

Port: - 443

Description: The remote web server is configured such that it does not return '404 Not Found' error codes when a non existent file is requested, perhaps returning instead a site map, search page or authentication page.

Nessus has enabled some counter measures for this. However, they might be insufficient. If a great number of security holes are produced for this port, they might not all be accurate.

Solution :- To remediate the Web Server No 404 Error Code Check issue, the web server should be configured to properly return the standard HTTP 404 Not Found response when a user requests a non-existent page or resource. The server must avoid returning a HTTP 200 OK response for invalid URLs, as this can mislead browsers, search engines, and security tools. Administrators should review and update the web server configuration (such as Apache, Nginx, or IIS) to ensure that invalid or missing resources correctly trigger a HTTP 404 Not Found or, if appropriate, HTTP 410 Gone response. Additionally, implement a properly configured custom error page while maintaining the correct HTTP status code in the server response header. Regular testing and vulnerability scanning should also be performed to verify that the server consistently returns the correct status codes for non-existent resources.

Business Impact :- If a web server fails to return the correct HTTP 404 Not Found for non-existent pages, it can inadvertently expose information about the website's structure, which increases the organization's attack surface. Attackers may use this behavior to enumerate directories, identify hidden resources, or probe for outdated or vulnerable pages, potentially leading to targeted attacks. From a business perspective, this could result in unauthorized access, data leakage, or defacement of web assets. Additionally, improper error handling can negatively affect SEO rankings and user experience, while also increasing the risk of compliance violations if sensitive or restricted resources are inadvertently discoverable. Overall, the organization faces potential reputational damage, operational disruption, and increased costs for mitigation and incident response.

8) **Vulnerability Name: -** 25220- TCP/IP Timestamps Supported : - Info

Plugin: - 25220

Port: - 443

Description :- The remote host implements TCP timestamps, as defined by RFC1323. A side effect of this feature is that the uptime of the remote host can sometimes be computed.

See Also

http://www.ietf.org/rfc/rfc1323.txt

Solution : To remediate the TCP/IP Timestamps Supported issue, configure network devices and servers to disable TCP timestamps in the TCP/IP stack. TCP timestamps can be used by attackers to fingerprint the operating system, measure system uptime, and conduct advanced reconnaissance attacks. On most operating systems, this can be disabled via system-level configuration:

After disabling, perform network scans to verify that TCP timestamps are no longer sent in packets. This reduces the information available to attackers for fingerprinting and reconnaissance, improving overall network security posture.

Business Impact : - The presence of TCP/IP Timestamps can expose sensitive information about the organization's systems, such as operating system type, kernel version, and system uptime, which attackers can use for targeted attacks or to plan sophisticated intrusions. From a business perspective, this increases the risk of network reconnaissance, unauthorized access,

or exploitation of known vulnerabilities in specific systems. Such exposure can lead to operational disruption, data breaches, regulatory compliance issues, and reputational damage. Additionally, it may increase incident response costs and the likelihood of financial losses if attackers leverage this information to compromise critical infrastructure or sensitive data.

9) Vulnerability Name: - 11936 - OS Identification : - Info

Plugin: - 11936

Port: - 443

Description :- Using a combination of remote probes (e.g., TCP/IP, SMB, HTTP, NTP, SNMP, etc.), it is possible to guess the name of the remote operating system in use. It is also possible sometimes to guess the version of the operating system.

Solution :- To mitigate risks associated with OS Identification, organizations should implement measures to reduce the ability of attackers to determine the operating system of networked devices. Key solutions include These measures reduce the likelihood that attackers can accurately identify the OS, lowering the risk of targeted attacks and exploitation of known vulnerabilities.

Business Impact :- The ability to identify an organization's OS Identification exposes critical information about its infrastructure, which attackers can leverage to target specific vulnerabilities associated with that operating system. From a business perspective, this increases the likelihood of successful cyberattacks, including unauthorized access, malware deployment, or exploitation of unpatched vulnerabilities. Such incidents can lead to data breaches, operational disruption, regulatory non-compliance, financial losses, and reputational damage. Additionally, OS fingerprinting can make it easier for attackers to perform reconnaissance and plan advanced attacks, increasing the organization's overall security risk and potential incident response costs.

10) **Vulnerability Name: -** 10919 - Open Port Re-check : - Info

Plugin: - 10919

Port: - 443

Description :- One of several ports that were previously open are now closed or unresponsive.

There are several possible reasons for this :

- The scan may have caused a service to freeze or stop running.
- An administrator may have stopped a particular service during the scanning process.

This might be an availability problem related to the following :

- A network outage has been experienced during the scan, and the remote network cannot be reached anymore by the scanner.
- This scanner may has been blacklisted by the system administrator or by an automatic intrusion detection / prevention system that detected the scan.
- The remote host is now down, either because a user turned it off during the scan or because a select denial of service was effective.

In any case, the audit of the remote host might be incomplete and may need to be done again.

Solution :- Steps to resolve this issue include :

- Increase checks_read_timeout and/or reduce max_checks.
- Disable any IPS during the Nessus scan

Business Impact :- The detection of Open Port on a system indicates that network services are exposed and listening for connections. From a business perspective, open ports increase the attack surface, allowing attackers to probe for vulnerabilities, exploit unpatched services, or gain unauthorized access to internal systems. If exploited, this can result in data breaches, service disruptions, regulatory compliance violations, financial losses, and reputational damage. Additionally, publicly accessible ports can enable lateral movement within the network, amplifying the potential impact of an attack and increasing operational and incident response costs for the organization. Regular re-checks and proper management of open ports are critical to minimize these risks.

Stage 3

Title: - Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

• Legacy VPN Architecture

Legacy VPN architecture is a traditional remote access solution that creates an encrypted communication tunnel between remote users and an organization's internal network. This connection is typically established through on-premises VPN appliances such as VPN concentrators or gateway devices located in the data center. Once users authenticate successfully, they are assigned an internal IP address and are treated as part of the internal network.

This architecture follows the traditional **castle-and-moat security model**, where the internal network is considered trusted and the external internet is considered untrusted. The VPN gateway acts as the entry point into the trusted environment. However, after authentication, users are granted broad access to internal resources, which increases the risk of unauthorized access if credentials or devices are compromised.

• Limitations of Legacy VPN

Although VPN technology was effective when most employees worked inside corporate offices, it presents several security and operational limitations in modern distributed environments.

The major limitations include:

1. **Over-privileged Network Access**: Once connected, users obtain network-level access instead of application-level access. This allows attackers to explore the internal network if a user account is compromised.

2. **Increased Attack Surface**: VPN gateways must expose public IP addresses and open ports to allow remote connections. These exposed interfaces become targets for scanning, brute-force attacks, and exploitation of vulnerabilities.

3. **Performance and Latency Issues:** VPN traffic is often routed through the organization's data center before reaching cloud services, causing increased latency and slower user experience.

4. **Scalability Constraints**: Traditional VPN appliances have hardware limitations. When many users connect simultaneously, the device may experience congestion or require costly hardware upgrades.

5.**High Maintenance Requirements:** IT administrators must regularly update firmware, manage certificates, patch vulnerabilities, and maintain VPN hardware infrastructure.

• The Problem: Lateral Movement and Attack Surface

The most critical issues associated with legacy VPN architecture are **expanded attack surface and lateral movement within the network**.

Attack Surface:

VPN gateways that are exposed to the public internet can be discovered by attackers through scanning tools. Once identified, attackers may attempt to exploit vulnerabilities or perform credential-based attacks to gain access.

Lateral Movement:

After an attacker gains VPN access using stolen credentials or compromised devices, they may move laterally across the internal network. This allows attackers to scan systems, locate sensitive data, and compromise additional servers.

Common lateral movement activities include:

• Scanning internal servers and services

• Exploiting vulnerable applications or databases

• Accessing file shares and confidential data

• Deploying malware or ransomware within the network

• Zero Trust Architecture

Zero Trust Architecture (ZTA) is a modern cybersecurity framework designed to eliminate the weaknesses of traditional network security models. Instead of trusting users based on

network location, Zero Trust continuously verifies identity, device health, and access context before granting access.

The Zero Trust approach follows the principle Never Trust, Always Verify.

The key principles of Zero Trust include:

1.**Assume Breach**: Systems are designed with the assumption that attackers may already be present in the environment.

2. **Verify Explicitly:** Every access request is authenticated and validated using identity, device posture, and contextual information.

3. **Least Privilege Access:** Users are granted only the minimum level of access required to perform their tasks.

4**. Micro-Segmentation:** Applications and resources are isolated from each other to prevent unauthorized movement inside the network.

• Zscaler Zero Trust Solution

Zscaler provides a **cloud-native Zero Trust platform** that replaces traditional VPN architecture by enabling secure access to applications without exposing the internal network.

The Zscaler platform mainly includes two services:

1. **Zscaler Private Access (ZPA):**

ZPA enables secure remote access to internal applications without connecting users to the corporate network. It establishes a direct connection between users and authorized applications using identity-based policies.

2. **Zscaler Internet Access (ZIA):**

ZIA functions as a secure internet gateway that inspects all internet traffic for threats, malware, and data leakage, ensuring safe internet usage for remote and on-premise users.

Together, these services create a comprehensive **Zero Trust Network Access (ZTNA)** environment that improves both security and user experience.

• How Zscaler Eliminates Attack Surface

Zscaler significantly reduces the attack surface by removing direct exposure of internal applications to the public internet.

This is achieved through the following mechanisms:

1. **No Inbound Connections**:

Zscaler App Connectors establish outbound connections to the Zscaler cloud, eliminating the need to open inbound firewall ports.

2. **Application Invisibility:**

Internal applications are never directly exposed to external networks, making them invisible to attackers scanning the internet.

3. **Secure DNS Handling:**

Application addresses are resolved within the Zscaler environment, preventing exposure through public DNS infrastructure.

4. **Brokered Connections:**

The Zscaler cloud acts as a secure intermediary between users and applications, ensuring both sides remain hidden from each other.

• How Zscaler Prevents Lateral Movement

Zscaler prevents attackers from moving laterally inside the network by ensuring that users connect directly to applications rather than the network itself.

The mechanisms include:

1. **Application-Level Segmentation:**

Users access only the specific applications they are authorized to use.

2. **No Network Access:**

Users are not assigned internal IP addresses, preventing them from scanning or discovering other resources.

3. **Identity-Based Policies:**

Access is granted based on user identity, device posture, and security policies instead of network location.

4. **Continuous Monitoring:**

Zscaler continuously monitors sessions and can terminate suspicious connections instantly.

• Zscaler Architecture Components

The Zscaler architecture consists of several components that work together to deliver secure Zero Trust **access.**

1. Zscaler Client Connector:

A lightweight application installed on user devices that securely routes traffic to Zscaler services.

2. Zscaler App Connector:

A virtual machine deployed within the organization's infrastructure that securely connects internal applications to the Zscaler cloud.

3. Zscaler Cloud Platform:

A globally distributed security cloud responsible for enforcing policies, inspecting traffic, and managing connections.

4. Zscaler Admin Portal:

A centralized management interface used by administrators to configure security policies, user access rules, and monitoring capabilities.

• Integration Points

Zscaler integrates with existing enterprise security infrastructure to enhance protection.

1. **Identity Provider Integration:**

Integration with identity platforms such as Azure AD or Okta enables secure authentication and single sign-on capabilities.

2. Endpoint Protection Integration:

Integration with endpoint security tools allows verification of device health before granting access.

3. SIEM Integration:

Security logs can be forwarded to SIEM platforms for centralized monitoring and analysis.

4. Threat Intelligence Integration:

External threat intelligence sources can be integrated to block access to malicious domains, IP addresses, and URLs.

• Deployment Methodology

The migration from legacy VPN to Zscaler Zero Trust follows a structured deployment process:

Phase 1: Discovery and Planning

Identify applications, users, and network requirements.

Phase 2: Infrastructure Deployment

Deploy Zscaler connectors and integrate identity services.

Phase 3: Policy Configuration

Create access policies based on user roles and security requirements.

Phase 4: Pilot Deployment

Test the system with a small group of users to validate functionality.

Phase 5: Full Deployment and Migration

Gradually migrate all users and decommission legacy VPN systems.

Phase 6: Optimization and Continuous Improvement

Monitor logs, refine policies, and continuously improve security posture.

• Threat Intelligence in Zscaler Environment

Threat intelligence enhances security by providing real-time insights into malicious activities and potential threats.

Sources of threat intelligence include:

• Zscaler security logs

• External threat intelligence feeds

• Identity provider authentication logs

• Endpoint detection and response systems

These intelligence sources enable proactive threat detection, faster incident response, and improved network visibility.

• Incident Response in Zero Trust Model

Zero Trust architecture significantly improves incident response capabilities.

Incident response involves the following steps:

1**. Detection:** Identify suspicious behavior through monitoring tools.

2. Containment: Immediately isolate compromised users or devices.

3. Eradication: Remove threats by resetting credentials and cleaning infected systems.

4. Recovery: Restore secure access after remediation.

5. Post-Incident Analysis: Analyse logs and update security policies to prevent future attacks.

The Zero Trust model limits the impact of security incidents by preventing attackers from moving across the network and accessing additional resources.

• Benefits of Zscaler Zero Trust Architecture

The implementation of a **cloud-native Zscaler Zero Trust architecture** provides several security and operational advantages compared to traditional VPN-based access systems. Some of the key benefits include:

1. Improved Network Security

Zero Trust ensures that every access request is verified based on user identity, device health, and security policies. This reduces the chances of unauthorized access and strengthens overall network protection.

2. Reduced Attack Surface

By removing publicly exposed VPN gateways and hiding internal applications from the internet, Zscaler significantly reduces the number of entry points available to attackers.

3. Prevention of Lateral Movement

Users are connected directly to authorized applications instead of the internal network. This prevents attackers from scanning the network or moving laterally if an account is compromised.

4. Enhanced Visibility and Monitoring

Zscaler provides centralized monitoring of user activity, application access, and internet traffic. Security teams can analyze logs and detect suspicious behaviour more efficiently.

5. Better User Experience

The global Zscaler cloud infrastructure allows users to access applications directly through the nearest data center, reducing latency and improving overall performance.

6. Scalability and Flexibility

As a cloud-based solution, Zscaler can easily support large numbers of users without requiring additional hardware. Organizations can scale their infrastructure as needed.

7. Simplified Security Management

The platform eliminates the need for maintaining VPN hardware and simplifies security management through a centralized administration portal.

Conclusion: -

In conclusion, replacing legacy VPN architecture with a **Zscaler Zero Trust solution** provides a modern and effective approach to securing organizational networks. Traditional VPN systems rely on a trust-based model that grants broad network access once a user is authenticated. This model increases the risk of security breaches, especially in environments where remote access is common.

The Zero Trust model addresses these challenges by enforcing strict verification for every access request and by granting only the minimum level of access required. Through technologies such as **Zscaler Private Access (ZPA) and Zscaler Internet Access (ZIA)**, users are connected directly to applications instead of being placed on the internal network.

This transformation significantly reduces the attack surface, prevents lateral movement within the network, and enhances the organization's ability to monitor and respond to security threats. Additionally, the integration of identity providers, endpoint security tools, and threat intelligence platforms strengthens the overall cybersecurity framework.

Overall, the adoption of a **cloud-native Zero Trust architecture** helps organizations build a secure, scalable, and future-ready network environment capable of defending against evolving cyber threats.

Future Scope: -

The implementation of Zero Trust using Zscaler opens several opportunities for further improvements and advancements in cybersecurity. Future developments can enhance security, automation, and system efficiency.

1. Integration of Artificial Intelligence and Machine Learning

AI and ML technologies can be integrated with Zero Trust platforms to analyze user behaviour and detect anomalies automatically, enabling faster threat detection and response.

2. Advanced Threat Intelligence Integration

Future systems can incorporate more threat intelligence feeds from global security communities to identify and block emerging cyber threats in real time.

3. Automation of Security Policies

Automated policy management can dynamically adjust security controls based on risk levels, user behaviour, and device posture.

4. Expansion to IoT and Cloud Environments

Zero Trust frameworks can be extended to secure Internet of Things (IoT) devices and cloud-native applications, ensuring protection across all digital environments.

5. Enhanced User Behaviour Analytics (UBA)

Future implementations can utilize advanced analytics to detect insider threats and compromised accounts by analysing patterns in user activity.

6. Integration with Advanced SOC and SIEM Systems

Deeper integration with Security Operations Centers (SOC) and SIEM platforms will enable automated incident response and improved monitoring capabilities.

With continuous technological advancements, Zero Trust architectures will play a crucial role in protecting modern digital infrastructures and ensuring secure access to applications and data.

Topics-Explored

collection and aggregation, standardization and normalization, threat intelligence

analysis, information sharing and distribution, integration with security tools, automation and orchestration, incident response support, threat intelligence feeds, and the role of SOC and SIEM in security monitoring.

Tools explored:

During the course of this project, several cybersecurity and vulnerability assessment tools were explored, including **Nmap** for network scanning, **Metasploit** for penetration testing, **Nessus** for vulnerability assessment, **Kali Linux** as a penetration testing platform, **OWASP ZAP** for web application security testing, and **Burp Suite** for identifying and analyzing web application vulnerabilities.

THE END